

Caso Photoshop27Full: compromissione di account e correlazione con Ahefi / Hekodex

Report tecnico indipendente · 8 ottobre 2026 · Versione 1.0 · Condivisione pubblica redatta

Classificazione: incidente di compromissione Windows con persistenza, componente classificato come information stealer e successivo abuso di account Instagram e Discord. **Attribuzione:** non determinata. **Livello di confidenza:** alto sull'infezione e sulla corrispondenza degli indicatori; limitato sull'infrastruttura di esfiltrazione.

Messaggio centrale. Un falso installer Photoshop ha preceduto la compromissione di diversi account. Sul computer sono stati rilevati quattro eseguibili i cui **nomi completi, con suffissi alfanumerici**, coincidono con quelli descritti pubblicamente in un caso legato all'estensione VS Code Ahefi, insieme a tre identificativi di persistenza identici. Gli hash dei quattro eseguibili, tuttavia, **differiscono**. L'account Instagram e l'account Discord compromessi hanno entrambi diffuso il link a **hekodex[.]com**, sito segnalato in relazione a promozioni crypto sospette. **Non è dimostrato** che Ahefi e Hekodex condividano gli stessi operatori o che Hekodex sia un endpoint di esfiltrazione.

1. Ambito, metodologia e limiti

Questa analisi utilizza: (1) due report Malwarebytes forniti dalla vittima, incluso uno relativo alla scansione del 6 ottobre 2026; (2) metadati, hash e risultati di analisi statica/dinamica raccolti su campioni contraffatti Photoshop; (3) analisi in VirtualBox con Windows 11 e Kali Linux su sola rete interna `malnet`, senza NAT/bridge, usando Sysmon, Procmon, disassemblaggio PE e hook Node.js; (4) fonti pubbliche, elencate alla fine.

Limiti: non è disponibile una cattura di rete del PC originariamente compromesso. Non sono stati verificati tutti i binari eliminati dall'infezione iniziale. Le prove raccolte nella VM riguardano un pacchetto MSI recuperato successivamente; i due ZIP di tale acquisizione contenevano lo stesso MSI, ma l'EXE inizialmente rilevato da Malwarebytes ha SHA-256 diverso. Nessun rapporto dimostra l'identità completa delle catene di installazione EXE/MSI. Le informazioni di terzi su Ahefi sono autoriferite o analisi indipendenti, non attribuzioni ufficiali.

2. Sequenza osservata

Periodo	Evento	Evidenza
6 ottobre, prima della scansione	Esecuzione di <code>Photoshop27Full.exe</code> proveniente da un pacchetto presentato come Photoshop	Tracce locali e rilevamento Malwarebytes
6 ottobre, ore 14:31	Malwarebytes rileva 23 elementi , tutti messi in quarantena	Log originale [F1]
Subito dopo la compromissione	Accessi non autorizzati / perdita di controllo di account, inclusi Instagram e Discord	Riscontro diretto dell'utente
6-7 ottobre	Sia Instagram sia Discord diffondono un link promozionale a <code>hekodex[.]com</code>	Riscontro diretto dell'utente; convergenza con segnalazioni pubbliche [P3-P5]
Dopo la bonifica	Reinstallazione completa di Windows e revoca delle sessioni degli account	Operazioni svolte dall'utente
7 ottobre	Reverse engineering su variante MSI in VM isolata	Log di test, Sysmon, Procmon e disassemblaggio

3. Evidenza dell'infezione originale

La scansione Malwarebytes [F1] registra quattro processi/moduli associati a `ProManagerc7e51.exe`, `ProUpdate7dd338.exe` e `NetHost1dcc90.exe`, oltre al file `AppManagerServicef7ad.exe`. La persistenza include `UpdateHost_1117`, `MaintainHost_058f` e il servizio `CheckManager_29ce`. Compare inoltre un'esclusione di Windows Defender per `SVCHOST.EXE`. Lo stesso report classifica l'installer originale come `Spyware.InfoStealer.Electron.Generic`, etichetta di rilevamento **non sufficiente da sola** a descrivere con precisione tutto il comportamento.

SHA-256 del file originale `Photoshop27Full.exe` :

`6a4ebb1eb8c91f9eb89cb4059269be601758bbea911efa24e223263bdd4ae137`

Il file è stato segnalato nel percorso temporaneo dell'archivio estratto. La compromissione degli account e le attività persistenti rendono l'incidente concretamente grave; **non dimostrano da sole** quali database browser, password, cookie o documenti siano stati sottratti né l'indirizzo del destinatario.

Quattro binari osservati e hash esatti

File	SHA-256 (caso locale)	Rilevamento
<code>ProManagerc7e51.exe</code>	<code>388967831f49e57486244a4614cb6e71870478418e8c74ef0551d87b5c882ebf</code>	Trojan.Crypt
<code>ProUpdate7dd338.exe</code>	<code>567b50a6e1f2e123d0b96f7a9ff4891097b6cbf90a8676e9b96f99010ed2df76</code>	Trojan.MalPack.PES
<code>NetHost1dcc90.exe</code>	<code>5e19d99333b1d5f48c17a56b76436221d97c59ee416a3a2bdc4255abdb1cc90</code>	Backdoor.Agent
<code>AppManagerServicef7ad.exe</code>	<code>bbe1c6043618cd389e158774747cb9d73b02eb9d541ff4b8a67808af18e3ac2c</code>	Malware.AI

Nota: l'hash di `NetHost` è riportato senza spazi nel file IOC allegato; la visualizzazione spezzata nella tabella è solo per leggibilità.

4. Correlazione con Ahefi: forte sugli identificativi, non sull'attribuzione

Il resoconto di una vittima dell'estensione VS Code Ahefi [P1] include, **con gli stessi caratteri e suffissi**, i seguenti sette indicatori del nostro incidente: `NetHost1dcc90.exe`, `ProManagerc7e51.exe`, `ProUpdate7dd338.exe`, `AppManagerServicef7ad.exe`, `CheckManager_29ce`, `MaintainHost_058f`, `UpdateHost_1117`.

Questa corrispondenza di nomi insoliti è un **indicatore forte di componente o catena di rilascio condivisa**. Tuttavia gli hash SHA-256 pubblicati dall'altra vittima **non coincidono** con quelli raccolti qui; i binari non sono byte-per-byte identici. Non si può distinguere ancora fra build differenti, riuso di un toolkit, un servizio di distribuzione condiviso o operatori differenti.

Un'analisi statica indipendente del pacchetto Ahefi v1.0.4 [P2] descrive un'estensione capace di recuperare da un endpoint remoto istruzioni e payload cifrati, quindi avviarli su Windows. È un possibile meccanismo di distribuzione degli stessi componenti, **non una prova che l'utente abbia installato Ahefi o che il falso Photoshop comunichi con `ahefi[.]com`**.

5. Hekodex e propagazione tramite due piattaforme

Secondo il resoconto diretto della vittima, il link a `hekodex[.]com` è stato inviato **sia tramite l'account Instagram compromesso sia tramite Discord**. Un utente Reddit [P3] ha descritto il 5 ottobre un DM Instagram da una persona conosciuta con un link crypto e un'immagine promozionale manipolata; una successiva analisi [P4]

mette in relazione Hekodex con questo schema. Le fonti di reputazione [P5] riportano la creazione del dominio il **3 ottobre 2026**, hosting tramite Cloudflare e segnali di rischio, con risultati dei motori antimalware variabili nel tempo.

Interpretazione prudente: Hekodex è un **indicatore della campagna di abuso e propagazione degli account**. Non è stato rilevato nei log di connessione dell'infezione originaria e **non è stato dimostrato** come server di comando e controllo, raccolta cookie o esfiltrazione. L'IP di Cloudflare non consente di attribuire l'origin server e non va utilizzato per attribuire un operatore.

6. Risultati della variante MSI analizzata in laboratorio

I due archivi ZIP scaricati successivamente avevano hash diversi, ma contenevano un identico `Photoshop27Full.msi` (SHA-256 `86d0759c3fb2c1ec6e40c5c4518a6641e37d806a422880ee66feb62f256304e4`). Il pacchetto impersonava il prodotto `WoodPoint Excel Export` e avviava `node.exe` e script JavaScript offuscati. Nella VM è stato osservato questo percorso:

`MSI → node.exe/y.js → clik5o3.js → addon N-API #1 → addon N-API #2 → file PE x64 da 388.112 byte`

Due addon nativi temporanei, caricati realmente in memoria dal processo Node, avevano SHA-256:

- 309.248 byte: `a8f8016f2f91ee3c4df9e9fc67f861c4aeaa960f70e89d51704822fd6022a756` ;
- 317.440 byte: `0fcfa35275a5afbac12d483230c4d1cd9fc4e8bc3ec0798323ece06a27a4603e` .

L'analisi degli export ha identificato funzioni N-API offuscate (`kjtt61h2k` , `gxltqfyj` , `wvvc0sf52` e altre). Il primo addon contiene un percorso di validazione crittografica e chiamate BCrypt; non basta per dedurre furto di password. Dal secondo stadio è stato estratto il PE x64 di **388.112 byte**, hash `0d75e404a160b180039257aa1d16f36d2732d60bc281cfc4e411517cb07c7001` . Il flusso di esecuzione si interrompeva con **Error: h** mentre la funzione nativa riceveva il buffer del PE. Non è stata stabilita la causa dell'errore.

Nelle prove con Internet simulata **non sono state osservate comunicazioni DNS/HTTP attribuibili al malware**, né letture confermate dei file-esca `Login Data` , `Cookies` e `Local State` di Chrome/Edge. **Questo è un limite del percorso eseguito in VM, non una prova che il malware non possa rubare dati altrove.**

7. Valutazione finale e livelli di certezza

Affermazione	Valutazione
Compromissione Windows e persistenza	Confermato dal log locale
Classificazione stealer dell'installer	Rilevamento documentato (non analisi completa delle capacità)
Stessi sette indicatori di un caso Ahefi pubblico	Confermato dal confronto testuale
Stessi file binari del caso Ahefi	No: hash differenti
Propagazione Hekodex via Instagram e Discord	Testimonianza diretta della vittima
Identità tra operatori Ahefi e Hekodex	Non dimostrato
Hekodex come server di esfiltrazione	Non dimostrato
Password/cookie/documenti specifici sottratti	Non determinabile dai dati disponibili
Identità della catena EXE originale con MSI successivo	Non dimostrata

8. Indicatori e azioni raccomandate

Gli indicatori puntuali sono nel file `indicators.csv` allegato. I nomi di processo e i valori di persistenza **non vanno trattati come firme universali della famiglia**: possono variare, essere riutilizzati o apparire in contesti diversi. Cercare insieme più evidenze e valutare i relativi hash.

Per i sistemi compromessi: isolare il dispositivo; conservare le evidenze; rimuovere la persistenza o preferibilmente reinstallare da supporto affidabile; revocare sessioni e token; cambiare password dal dispositivo pulito; ruotare le chiavi API potenzialmente esposte; verificare gli accessi a Instagram, Discord, email e altri servizi; avvertire i destinatari dei messaggi fraudolenti; segnalare `hekodex[.]com` ai servizi coinvolti. **Non aprire i file sospetti sull'host e non visitare il dominio per "testarlo".**

9. Fonti e provenienza

[F1] Report Malwarebytes originale, scansione 6 ottobre 2026 ore 14:31, fornito privatamente dall'utente; versione pubblica anonimizzata. **[F2]** Secondo report Malwarebytes, scansione profonda 6 ottobre 2026. **[L1]** Laboratorio isolato Windows/Kali: SHA-256, Procmon, Sysmon, `objdump`, hook N-API/Node; materiale e screenshot forniti dall'utente.

[P1] Testimonianza di una vittima Ahefi, r/malwares: https://www.reddit.com/r/malwares/comments/1wpbhu7/from_my_brothers_wake_to_getting_infected_by_ahefi/

[P2] Analisi indipendente Ahefi v1.0.4, linux.sb, 25 settembre 2026: <https://linux.sb/topic/23801>

[P3] Segnalazione Hekodex, r/antivirus, 5 ottobre 2026: https://www.reddit.com/r/antivirus/comments/1wygj7r/mrbeast_hekodex_crypto_scam_question/

[P4] Analisi Hekodex, HowToRemove.Guide, 6 ottobre 2026: <https://howtoremove.guide/hekodex-com-scam-casino/>

[P5] Scanner di reputazione dominio: <https://scanner.pcrisk.com/scan-results/hekodex.com> e <https://tools.malwaretips.com/url-scan/hekodex.com>

[P6] Repository GitHub associato al marketing del falso Photoshop (il proprietario non è attribuito come operatore del malware): `github[.]com/stormkazekagematch/adobe-ps-v27-core`.

Nota sulla pubblicazione: nessun nome anagrafico, indirizzo email, numero di telefono, token, percorso Windows contenente il nome della vittima o file eseguibile malevolo è pubblicato in questo report. La segnalazione è tecnica e difensiva; non costituisce attribuzione a individui o organizzazioni.